

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

The check is green. The parser is still broken.

```
task check          PASS
```

```
external case "1,,3"  REJECT expected  
actual parser output  [1, 3]
```

Would you accept the patch?

Recorded Linux isolation run

One job. Four grants.

Fix the parser. Publish the task report.

Identity Files Data release Acceptance

Independent synthetic experiments. Worker code is untrusted.

Linux namespaces separate workers. Controller and host remain trusted.

01 / It can read another project's data

```
request: GET /projects/other/private
```

runner credential	200 + synthetic fixture
task credential	403
task input	200
expired credential	403

The service enforces task scope, audience and expiry.

Recorded Linux isolation run

02 / It can change another job's state

worker writes /shared/next-job.json

writable bind	host fixture changes
read-only bind	write denied; fixture unchanged
/output	patch remains writable

Observed with real bind mounts

03 / It can send data to another account

same service, different recipient

team/reports intended destination

other/uploads receives synthetic private data

Repair: broker fixes recipient and body.

Direct fixture-service route is unavailable.

Extra fields denied. The permitted report still arrives.

Recorded Linux isolation run

04 / It can change what we call success

```
# Worker rewrites the workspace checker:  
print("PASS")  
raise SystemExit(0)
```

Now the opening makes sense: the worker rewrote the checker.

Recorded Linux isolation run

An independent decision

Input	Buggy parser	Fixed parser
1,2,3	Accept	Accept
1,,3	Accept	Reject
Empty input	Accept	Reject
-2, 3	Accept	Accept
x	Reject	Reject

Recorded Linux isolation run

Which bytes passed?

Artifact swapped after verification	Denied
Approval reused	Denied
Verified artifact, current run	Accepted
History rewritten and rehashed	Detected

The controller holds the approval key and original history head.

Recorded Linux isolation run

Back to the original job

1. Worker receives input and writes the fixed parser.
2. External verifier checks the frozen artifact.
3. Gate accepts exactly those bytes.
4. Broker publishes the fixed task report.

1,,3 now returns REJECT. The report reaches the team.

Recorded Linux isolation run

Four boundaries to check

Question

Whose identity?

Which files?

Which recipient and contents?

Who can approve these bytes?

Enforcing owner

Service grant

Host mount policy

Broker and network policy

External verifier and gate

Process isolation separates the worker from these enforcing components.

THE QUESTION TO TAKE HOME

Who gave this process the authority?

github.com/zozo123/nyc-talk

Yossi Eliaz

Appendix / Reproduction

```
make demo          # Linux + bubblewrap; strict
make reference     # policy checks; explicit skips
make deck          # evidence check + PDF build
python3 tools/present.py credentials
```

29 checks passed. Source digests and subprocess observations are recorded.

Appendix / Limits of the evidence

Deterministic scripts exercise chosen actions.

Namespace and mount checks require the isolated run.

Five parser cases establish one demonstrated repair.

Controller code, keys and decisions remain trusted.

No cgroup, kernel-exploit, covert-channel or universal security claim.

Appendix / Primary references

Linux environ(7)

Environment inheritance

Docker bind mounts

Host filesystem effects and read-only mounts

RFC 9700

Access-token privilege restriction

SLSA artifact verification

Trusted provenance and artifact identity